

발 간 등 록 번 호

11-1790432-100004-01

일반수신자 등재 안내서

2025. 03.



개인정보보호위원회

Personal Information Protection Commission

발 간 등 록 번 호
11-1790432-100004-01

일반수신자 등재 안내서

2025. 03.



개인정보보호위원회
Personal Information Protection Commission



일반수신자 등재 안내서

안내 사항

발간 목적

본 안내서는 일반수신자 등재 시 제출 서류 등 갖추어야 하는 사항, 확인 사항별 검토내용을 안내함으로써 일반수신자 등재 준비에 대한 이해를 돕고, 확인사항 등 해석에 대한 명확한 기준을 안내하기 위해 작성되었습니다.

제·개정 이력

일자	주요 내용
'25. 03. 발간	일반수신자 등재 시 참고해야 할 「일반수신자 등재 절차」 안내

재검토 기한

안내서의 최신성을 유지하기 위해 발간일(2025년 03월)을 기준으로 매 3년이 되는 시점(매 3년째의 12.31.까지를 말함)마다 보완 및 개선 등의 조치를 취할 예정입니다.

저작권 표시

본 안내서 내용의 무단전재를 금하며, 가공·인용할 때는 출처를 밝혀 주시기 바랍니다.

* 출처 : 개인정보보호위원회, 「일반수신자 등재 안내서」 2025.02.

문의처

본 안내서 내용 관련 문의는 개인정보보호위원회 범정부 마이데이터추진단 서비스혁신팀(☎02-2100-3185)으로 문의주시기 바랍니다.

법적 근거

「개인정보 보호법」제35조의2제2항 및 동법 시행령 제42조의2부터 제42조의8, 제42조의15 등

※ 법령 최신 자료는 국가법령정보센터(www.law.go.kr), 일반수신자 등재 안내서 최신 자료는 개인정보보호위원회 누리집*, 개인정보 포털**을 참고

* 개인정보보호위원회 누리집(www.pipc.go.kr) : 법령 > 법령정보 > 안내서

** 개인정보 포털(www.privacy.go.kr) : 자료 > 자료보기 > 안내서

C O N T E N T S

I

개요 7

- 1. 일반수신자 개요 7
- 2. 일반수신자 등재 절차 11

II

일반수신자 등재신청서 작성방법 14

- 1. 일반수신자 등재신청서 양식 14
- 2. 등재신청서 신청서류 작성요령 15

III

일반수신자 확인사항 해설 17

- 1. 개인정보관리 계획서 17
- 2. 전송 요구 관련 제반 시스템 19
- 3. 보호체계 40

- [부록] 일반수신자 등재 Q&A 66

I 개요

1 일반수신자 개요

가. 등재대상

- 개인정보 보호법 제35조의2제2항제2호에 따라 개인정보를 전송받아 고유의 업무를 수행하는 과정에서 수집한 정보의 진위 여부 등을 확인하는 업무를 수행하는 기관·법인 또는 단체
 - 일반수신자는 개인정보를 전송받아 진위여부 등을 확인하는 업무만을 수행할 수 있으며, 개인정보관리 전문기관 지정을 받지 않고 통합조회, 맞춤형 서비스, 연구, 교육 등을 위한 관리·분석하는 업무에 이용할 수 없음
 - 통신분야 개인정보 전송에 관한 고시 제2조에 규정한 별표에 따라 청구정보 및 납부정보는 일반수신자의 전송요구 대상에서 제외
 - 시행령 제42조의6제4항에 따라 보건의료정보는 일반수신자의 전송요구 대상에서 제외

〈일반전문기관과 비교〉

개인정보 보호법 시행령 제42조의4제1항 각호 구분에 따른 정보전송자가 보유한 개인정보를 전송받아 수집한 정보의 진위 여부 등을 확인하는 자는 일반수신자 등재를 하면 되지만, 전송받은 정보를 통합 조회하거나 분석하여 맞춤형 서비스, 연구, 교육 등에 이용하는 업무를 수행하고자하는 경우에는 개인정보 보호법 제35조의3제1항에 따라 일반전문기관 지정을 받아야 함

법률	시행령	고시
제35조의2(개인정보의 전송 요구) ① (생략) ② 정보주체는 매출액, 개인정보의 보유 규모, 개인정보 처리 능력, 산업별 특성 등을 고려하여 대통령령으로 정하는 기준에 해당하는 개인정보처리자에 대하여 제1항에 따른 전송 요구 대상인 개인정보를 기술적으로 허용되는 합리적인 범위에서 다음 각 호의 자에게 전송할 것을 요구할 수 있다.		

법률	시행령	고시
1. (생략) 2. 제29조에 따른 안전조치의무를 이행하고 대통령령으로 정하는 시설 및 기술 기준을 충족하는 자	제42조의3(일반수신자 기준) ① 법 제35조의2제2항제2호에서 “대통령령으로 정하는 시설 및 기술 기준을 충족하는 자”란 고유의 업무를 수행하는 과정에서 수집한 정보의 진위 여부 등을 확인하기 위하여 개인정보를 전송받는 자로서 다음 각 호의 사항에 관하여 보호위원회가 정하여 고시하는 시설 및 기술을 갖춘 자를 말한다. 1. 표준 전송 절차, 전송시스템 연계 및 전송 보안 기준 등을 충족하는 전송 요구 관련 시스템 2. 전송 이력의 기록·보관 및 전송 받은 개인정보의 분리 보관을 위한 시스템 3. 개인정보에 대한 불법적인 접근 및 침해 사고 방지를 위한 탐지 및 차단 시스템 4. 개인정보에 대한 접근권한 관리 및 접근 통제 시스템 ② 법 제29조에 따른 안전조치의무를 이행하고 제1항에 따른 시설 및 기술을 갖춘 자(이하 “일반수신자”라 한다)는 법 제35조의2제2항에 따른 전송 요구(이하 “제3자전송요구”라 한다)에 따라 개인정보를 전송받는 업무의 일부 또는 전부를 중지 또는 폐지하려는 경우에는 그 사실을 미리 제42조의9 제1항제1호에 따른 중계전문기관(이하 “중계전문기관”이라 한다)에 통지하고 법 제35조의4제2항에 따른 개인정보 전송 지원 플랫폼(이하 “개인정보 전송지원플랫폼”이라 한다)에 등재해야 한다.	제2조(정의) 이 고시에서 사용하는 용어의 뜻은 다음과 같다. 2. “일반수신자”란 법 제35조의2제2항제2호에 따라 법 제29조에 따른 안전조치의무를 이행하고 영 제42조의3제1항에 따른 시설 및 기술을 갖춘 자로서 고유의 업무를 수행하는 과정에서 수집한 정보의 진위 여부 등을 확인하기 위하여 개인정보를 전송받는 자를 말한다.

나. 일반수신자 시설 및 기술 기준

- 일반수신자는 개인정보 보호법 제29조에 따른 안전조치의무를 이행하고, 개인정보 보호법 시행령 제42조의3제1항제1호부터 제4호까지의 사항에 관하여 보호위원회가 정하여 고시하는 시설 및 기술 기준을 갖추어야 함
- 표준 전송 절차, 전송시스템 연계 및 전송 보안 기준 등을 충족하는 전송요구 관련 시스템, 전송 이력의 기록·보관 및 전송받은 개인정보의 분리 보관을 위한 시스템, 개인정보에 대한 불법적인 접근 및 침해사고 방지를 위한 탐지 및 차단 시스템, 개인정보에 대한 접근권한 관리 및 접근 통제 시스템을 갖추어야 함(구체적 사항은 확인 사항 해설 부분 참고)

참고 | 「개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시」 [별표 1]

구분	시설 및 기술
1. 전송 요구 관련 제반 시스템	1) 전송 관리 및 연계, 전송 이력 관리 기능 - 전송요구서 관리 및 정보주체 인증 기능 - 중계전문기관과의 연계 기능 - 개인정보전송지원플랫폼과의 연계 기능 - 개인정보 전송 이력의 기록·보관 기능 - 전송받은 정보의 분리·보관 기능 - 전송 내역의 중계전문기관을 통한 개인정보전송지원플랫폼 제출 기능 2) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및 보안시스템 구축 - 전송 요구 관련 시스템의 네트워크 구축 - 전송 요구 관련 시스템에 대한 침입탐지·차단 시스템 구축
2. 보호체계	1) 일반수신자 업무 관련 정보의 안전성 확보를 위한 내부 관리계획 ※ 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함 2) 개인정보 전송 이력의 기록·보관 및 점검 방안 3) 전송 요구 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근 권한의 관리 및 점검 체계 4) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 전송 요구 관련 시스템, 업무용 단말 등에 대한 접근통제 체계 - 전송 요구 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치 - 전송 요구 관련 시스템에 대한 외부 접속시 안전한 인증수단 등의 적용

* 그 외 법 제29조에 따라 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 함

다. 일반수신자 행위 원칙

- 일반수신자는 제3자 전송요구에 따라 개인정보를 전송받는 경우 아래 어느 하나에 해당하는 행위로 인하여 정보주체의 이익을 침해하거나 전송 처리 체계를 저해하지 않도록 노력해야 함 (개인정보 보호법 시행령 제42조의6제6항)

〈 개인정보 보호법 시행령 제42조의6제6항제1호부터 제8호까지〉

- 법 제16조제1항을 위반하여 전송 요구 목적과 관련 없는 개인정보를 전송하도록 요구하는 행위
- 법 제16조제3항에 따른 서비스 운영을 위하여 필수적인 경우가 아닌데도 전송받은 정보에 대한 제3자 제공 동의를 전송 요구와 동시에 받는 행위
- 법 제35조의2제1항·제2항에 따른 전송 요구 또는 법 제38조제1항에 따른 권리에 대한 대리 행사를 강요하거나 부당하게 유도하는 행위
- 법 제35조의3제1항에 따른 개인정보관리 전문기관의 지정을 받지 않고 같은 항 각 호의 업무를 수행하는 행위
- 정보주체의 동의 없이 제42조의5제2항에 따른 전송 요구 내용을 변경하여 개인정보를 요구하는 행위
- 자기 또는 제3자의 이익을 위하여 특정 정보주체의 이익을 침해하는 행위
- 정보주체의 전송 요구를 이유로 개인정보처리자의 전산설비에 지속적·반복적으로 접근하여 장애를 일으키는 행위
- 그 밖에 위와 유사한 행위로서 정보주체의 이익을 침해하거나 전송 처리 체계를 저해하는 행위

2 일반수신자 등재 절차

가. 개인정보 전송 지원 플랫폼 등재 대상

- 개인정보 보호법 제35조의2제2항제2호에 따라 개인정보를 전송받고자 하는 자는 개인정보 전송지원 플랫폼을 통해 등재를 신청하여야 함

개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

제15조(일반수신자 개인정보 전송 지원 플랫폼 등재 절차) ① 영 제42조의16제1항에 따라 일반수신자로서 정보를 전송받으려는 자는 별지 제5호서식의 일반수신자 등재신청서에 다음 각 호의 서류(「전자문서 및 전자거래 기본법」 제2조제1호에 따른 전자문서를 포함한다. 이하 같다)를 첨부하여 개인정보 전송 지원 플랫폼(이하 “개인정보전송지원플랫폼”이라 한다)에 등재를 신청해야 한다.

- 1. 개인정보 관리 계획서(고유의 업무 수행에 있어 전송받고자 하는 정보의 필요성 및 이용계획 포함)
- 2. 법 제29조에 따른 안전조치의무 이행을 증명할 수 있는 서류
- 3. 별표 1에 따른 일반수신자 시설 및 기술을 갖추었음을 증명할 수 있는 서류

② 보호위원회는 제1항에 따른 사항을 확인하여 법 제35조의2제2항제2호에 따른 일반수신자 기준을 충족하는 경우에는 해당 일반수신자를 개인정보전송지원플랫폼에 등재해야 한다.

나. 등재절차 및 방법

- 개인정보 보호법 제35조의2제2항에 따라 개인정보를 전송받고자 하는 자는 개인정보보호 위원회에 일반수신자 등재신청서를 제출하고 시설 및 기술, 안전조치의무 이행 등을 확인받은 후 개인정보 전송지원 플랫폼에 등재



다. 플랫폼 등재 신청

■ 등재신청

- 일반수신자로 등재하고자 하는 자는 일반수신자 등재신청서와 제출서류를 갖추어 개인정보 전송지원 플랫폼을 통해 등재 신청
 - **(제출서류)** 일반수신자 등재신청서, 개인정보 관리 계획서, 시설 및 기술 요건, 개인정보 보호법 제29조에 따른 안전조치의무 이행을 갖추었음을 입증할 수 있는 서류

■ 신청서 검토 및 접수

- 개인정보보호위원회는 일반수신자 등재신청서와 제출서류를 확인하고 누락된 사항이 있는지 검토하여 신청서를 접수하고 필요한 경우 보완 요청

라. 시설, 기술 요건 및 안전조치의무 이행 여부 확인

■ 심사위원회

- 개인정보보호위원회는 일반수신자 등재신청이 접수되면 일반수신자 시설 및 기술 요건, 개인정보 보호법 제29조에 따른 안전조치의무 이행 여부 확인을 위해 심사위원회를 구성
 - **(심사위원회 자격)** 개인정보 보호, 정보보호, 회계 및 지정권자가 정하는 관계 분야 등 지정요건에 관하여 학식과 경험이 풍부한 전문가

■ 확인 방법

- 심사위원회는 신청자가 제출한 서류를 기반으로 시설 및 기술 요건, 안전성 확보조치의무 이행 여부에 대해 서면 확인(필요 시 현장 확인)
 - **(서류확인)** 신청자가 제출한 서류를 기반으로 사업계획, 개인정보관리 계획, 안전성 확보조치 이행 여부, 시설 및 기술 기준 충족 여부 등에 대한 서류심사 진행
 - **(현장확인)** 서류심사 시 제출된 증빙자료로 정확한 확인이 어려워 현장 확인이 필요한 경우 시설 및 기술, 안전성 확보조치 등이 실제로 갖추어졌는지를 확인하기 위한 현장 확인 진행

마. 개인정보 전송지원 플랫폼 등재

■ 자격증명 발급

- 개인정보보호위원회는 일반수신자 등재 신청을 한 자가 시설 및 기술 요건을 갖추고 안전성 확보조치 의무 이행하였다고 확인한 경우 해당 신청자에게 일반수신자 자격증명 발급

■ 플랫폼 등재

- 개인정보보호위원회는 해당 일반수신자 명단을 개인정보 전송지원 플랫폼에 등재

II 일반수신자 등재신청서 작성방법

1 일반수신자 등재신청서 양식

■ 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시 [별지 제6호 서식]

일반수신자 등재신청서				
등재 신청자	기관·법인·단체명 (또는 명칭)			
	사업자등록번호 또는 법인등록번호			
	대표자 성명			
	주소 (주된 사무소 소재지)			
	주요 설비 및 시설의 설치 장소			
	홈페이지 주소			
담당자	담당자 성명			
	담당자 연락처	전화번호 전자우편		
「개인정보 보호법」 제35조의2제2항제2호 및 같은 법 제42조의16제1항, 「개인정보 전송 및 전문기관 지정 등에 관한 고시」 제15조제1항에 따라 일반수신자 등재를 위와 같이 신청합니다. 년 월 일 (서명 또는 인) 신청자 개인정보보호위원회 귀중				
첨부 서류	1. 개인정보 관리 계획서(고유의 업무 수행에 있어 전송받고자 하는 정보의 필요성 및 이용계획 포함) 2. 법 제29조에 따른 안전조치의무 이행을 증명할 수 있는 서류 3. 별표 1에 따른 일반수신자 시설 및 기술을 갖추었음을 증명할 수 있는 서류		수수료 없음	
처 리 절 차				
신청서 작성 신청자	→ 접 수 처리기관	→ 확 인 처리기관	→ 등재여부 결정 처리기관	→ 개인정보전송 지원플랫폼 등재 처리기관
210mm×297mm[(백상지(80g/㎡) 또는 중질지(80g/㎡)]				

2 등재신청서 작성요령 및 신청서류

가. 일반수신자 등재신청서

- 일반수신자로 등재하고자 하는 자는 일반수신자 등재신청서와 제출서류를 갖추어 개인정보 전송지원 플랫폼을 통해 등재신청

- 등재신청자

- 일반수신자로 등재하고자 하는 기관·법인·단체명, 해당 기관의 사업자등록번호 또는 법인등록번호, 대표자 성명, 주된 사무소 소재지 주소, 주요 설비 및 시설의 설치 장소*, 홈페이지 주소 기재

* 일반수신자 업무와 관련한 주요 설비 및 시설의 설치 장소 기재

- 담당자

- 일반수신자 업무를 담당하는 담당자, 일반수신자 업무와 관련하여 연락할 수 있는 전화번호, 전자우편 주소 기재

나. 신청서류

- 1) (개인정보 관리 계획서) 서비스 개요, 전송요구 계획, 개인정보 처리 계획, 서비스 가입, 전송 요구 철회, 전송 중단 요청시 대응 계획에 대한 사항 기재
- 2) (시설 및 기술 기준, 안전조치 의무 이행 입증 서류) 아래 내용에 관한 입증 자료 제출
(구체적 내용은 일반수신자 확인사항 해설 참고)

붙임

1 개인정보 관리 계획서 작성 예시

가. 개인정보 관리 계획서

작성 항목	기재 내용
1. 서비스 개요	○ 서비스 목적 및 추진 전략 ○ 서비스 특징 ○ 활용 데이터 - 전송 요구 데이터 항목, 전송 요구 외 추가 활용 데이터 유무 - 데이터 전송 주기 - 데이터 보유 기간 - 데이터 식별자(주민등록번호 or CI) 등
2. 전송요구 계획	○ 전송요구 계획서 - 전송요구 목적, 개인정보를 전송하는 자, 전송요구 대상 정보 항목, 전송요구 주기 및 기간, 전송을 요구하는 개인정보의 보유 및 이용기간 ○ 전송 요구 내용 변경 - 전송 요구 내용 변경 절차 및 방법(전송 요구 내용 변경 시 정보주체 동의 방법 포함)
3. 개인정보 처리 계획	○ 전체 개인정보 흐름도 ○ 개인정보 처리 계획서 - 개인정보 수집·이용 목적, 수집·이용 항목, 수집·이용 방법, 파기 방법 ○ 분리·보관 방법
4. 서비스 가입 및 탈퇴, 전송요구 철회, 전송중단 방법	○ 서비스 가입 및 탈퇴 방법 ○ 정보주체의 전송요구 변경, 철회, 전송중단 방법 ○ 정보주체의 전송요구 변경, 철회, 전송중단 시 대응 절차

III

일반수신자 확인사항 해설

1 개인정보 관리 계획서

■ 세부 설명

작성 항목	기재 내용
1. 서비스 개요	○ 서비스 목적이 명확하며 실현 가능한가? ○ 추진 전략이 구체적이고 실현가능한가? ○ 서비스 목적 및 내용이 일반수신자 업무로 구성되어 있는가? - 개인정보를 전송받아 확인하는 것 이외에 이를 맞춤형 서비스, 연구·교육, 유통·판매 등 처리하고 있지 않은가? - 사업 내용이 정보주체의 권리와 이익을 증대하기 위한 내용에 해당하는가? ○ 활용하려는 데이터가 구체적인가? ○ 서비스 목적을 고려할 때 전송 요구 데이터별 활용의 필요성이 있는가?
2. 전송요구 계획	○ 개인정보 보호법 시행령 제42조의5, 제42조의6에 따라 전송요구 방법이 작성되어 있는가? ○ 개인정보 보호법 시행령 제42조의5제3항에 따라 정보주체가 전송의 목적, 이용과 관련된 사항을 설명하고 있는가?
3. 개인정보 처리 계획	○ 개인정보 보호법 제15조, 제16조, 제23조, 제24조에 따라 개인정보 수집·이용에 관한 처리근거가 타당한가? ○ 개인정보 보호법 제22조, 제22조의2에 따라 개인정보 수집·이용 등 처리 방법이 적절한가? - 동의를 받지 않는 경우, 적절하게 고지하고 있는가? - 동의를 받는 경우, 동의항목 및 동의 방식이 적절한가? - 다크패턴 등 부당한 방법으로 수집·이용하고 있지 않은가? ○ 개인정보와 타 정보가 시스템에서 분리 보관되도록 설계되어 있는가? ○ 개인정보 보유·이용기간 도과 시 개인정보를 파기하도록 설계되어 있는가?
4. 서비스 가입 및 탈퇴, 전송요구 철회, 전송 중단 방법	○ 서비스 가입 절차가 적절한가? ○ 서비스 탈퇴 절차가 적절한가? ○ 서비스 가입 방법이 적절한가? ○ 서비스 탈퇴 방법이 적절한가? ○ 전송요구 변경, 철회, 전송 중단 방법이 적절한가? ○ 전송요구 철회, 전송 중단 시 파기 방법이 적절한가?

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송요구 계획 - 전송요구서, 전송요구 화면(UI, UX 등 캡처) • 개인정보 처리 계획 - 전체 개인정보 흐름도 - 개인정보 수집·이용 동의서, 개인정보 수집·이용 화면(캡처) • 전송요구 변경, 철회, 전송 중단 방법 및 절차 - 전송요구 변경, 철회, 전송중단 구현 화면(캡처) • 전송받은 정보에 대한 분리 보관 - 개인정보 흐름도, 시스템 설계도 포함

■ 미흡 사례

사례 1	• 사업 목적과 관련없는 개인정보 전송을 요구
사례 2	• 전송중단, 철회를 위한 절차가 구현되어 있지 않음
사례 3	• 전송요구 또는 개인정보 수집·이용·제공 방법이 다크패턴으로 이루어져 있음
사례 4	• 전송중단, 철회를 위한 절차가 구현되어 있지 않음
사례 5	• 전송중단 철회 시 파기 절차를 마련하고 있지 않음

2 전송 요구 관련 제반 시스템

2.1 전송 관리 및 연계, 전송 이력 관리 기능

2.1.1 전송요구서 관리 및 정보주체 인증 기능

세부 지정요건 및 주요 확인사항	
주요내용	정보주체 본인확인 및 전송요구서 작성·변경 화면 및 처리 기능을 갖추고, 전송요구서 작성 이후 정보주체로부터 전자서명을 받아 처리하는 기능을 갖추어야 한다.
주요 준비사항	① 정보주체 본인확인 및 전송요구 기능을 갖추고 있는가? ② 전송요구서 작성·변경 및 전자서명 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 정보주체 본인확인 및 전송요구 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 정보주체 본인확인을 수행하고, 정보전송자가 보유하고 있는 정보주체 식별자 유형에 맞춰 전송요구를 할 수 있도록 구현해야 한다.
 - 식별자 관리 유형은 전송지원 플랫폼에서 제공하는 정보전송자 등록정보 조회 API를 통해 조회 가능
 - 식별자 관리 유형은 연계정보, 개별식별자, 주민등록번호의 3가지 유형에 대하여 사전에 확인할 수 있어야 함
- 식별자 관리 유형이 개별식별자일 경우에 대하여 정보전송자가 개별인증을 통해 정보주체를 확인하고 정보수신자에게 권한(ID토큰)을 부여하는 절차를 마이데이터 서비스에서 처리할 수 있도록 기능을 갖추어야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 정보주체 본인확인 절차 • 정보전송자가 보유한 식별자 유형에 따른 전송요구절차

준비사항

② 전송요구서 작성·변경 및 전자서명 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 전송요구서 작성·변경 화면 및 전송요구서를 처리할 수 있는 기능을 갖추어야 한다.
 - 정보주체가 전송요구할 항목 선택, 입력 또는 확인 기능
 - 정보주체가 전송요구할 항목을 변경하고자 할 경우 변경 기능
 - ※ 화면 상으로는 변경이나, 실제 처리는 전송요구서를 재작성
 - 개인정보 수집·이용 동의
 - 정보주체가 작성한 전송요구서 생성 및 전송
- 전송요구서 작성 이후 정보주체에게 전자서명을 받아 처리하는 기능을 갖추도록 한다.
 - 정보전송자별로 전송요구서의 전자문서 생성
 - ※ 개별식별자 기반 전송요구서의 전자문서 생성 시 ID토큰을 포함하여 생성
 - 정보주체의 전자서명 화면
 - 전자서명 요청 및 결과 수신 등 처리

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송요구서 작성 및 변경 기능 • 전송요구서 전자문서 및 처리 기능 • 전자서명 화면 및 처리 기능

2.1.2 중계전문기관의 연계 기능

세부 지정요건 및 주요 확인사항	
주요내용	일반수신자는 접근토큰 발급 요청, 정보 조회 요청, 전송요구 철회 등 중계전문기관과의 API 연계 기능을 갖추어야 한다.
주요 준비사항	① 접근토큰 발급 요청 API 연계 기능을 갖추고 있는가? ② 정보 조회 요청 API 연계 기능을 갖추고 있는가? ③ 전송요구 철회 및 API 연계 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 접근토큰 발급 요청 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 중계전문기관이 제공하는 접근토큰 발급 요청 API 연계할 수 있는 기능을 갖추어야 한다.
 - 개별식별자 유형의 요청인 경우는 ID토큰을 포함하여야 함

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 접근토큰 발급 요청 API 연계 기능

준비사항

② 정보 조회 요청 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 중계전문기관이 제공하는 정보 조회 요청 API 연계할 수 있는 기능을 갖추어야 한다.
 - 정보 조회 요청 API를 호출할 경우 중계 전문기관이 발급한 접근토큰을 포함하여 호출
 - 정보 조회 요청 시 암호화 전송되도록 보호조치

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 정보 조회 요청 API 연계 기능

준비사항

③ 정보요구 철회 및 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 정보주체가 전송요구서를 선택하여 철회할 수 있도록 기능을 갖추어야 한다.
 - 정보주체로부터 철회 요청을 받은 경우 전송요구서 및 접근토큰 폐기
- 일반수신자는 철회 요청을 받으면 중계 전문기관이 제공하는 전송요구 철회 API 연계 기능을 갖추어야 한다.
 - API 연계 시 접근토큰 이용
 - 전송요구서 및 접근토큰 폐기 요청

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송요구 철회 요청 기능 • 전송요구 철회 API 연계 기능

2.1.3 개인정보 전송지원 플랫폼과의 연계 기능

세부 지정요건 및 주요 확인사항	
주요내용	일반수신자는 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추어야 한다.
주요 준비사항	① 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 연계하려는 기관의 정보를 개인정보 전송지원 플랫폼에서 주기적으로 조회하여 확인할 수 있는 API 연계 기능을 갖추어야 한다.
- 일반수신자는 정보전송자 정보 및 중계 전문기관 정보를 주기적으로 조회하여 확인할 수 있도록 API 연계 기능 구현

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보 전송지원 플랫폼과의 API 연계 기능

2.1.4 개인정보 전송 이력 기록·보관 기능

세부 지정요건 및 주요 확인사항	
주요내용	개인정보 전송 내역에 대한 기록·보관 및 조회할 수 있는 기능 또는 시스템을 갖추어야 한다.
주요 준비사항	① 전송 내역 기록·보관 및 조회할 수 있는 시스템을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송 내역 기록·보관 및 조회할 수 있는 시스템을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 전송 내역을 보관할 수 있는 시스템을 갖추어야 한다.
 - 전송 내역은 최소 3년간 보관될 수 있도록 충분한 저장 공간 또는 확장 가능한 구조로 구현
 - 전송 내역 조회 확인 기능(예, 별도 관리자 페이지 등) 구현
 - 전송 내역이 위·변조, 도난, 분실되지 않도록 안전한 보관 체계 마련
 - 전송 내역을 보관하는 시스템에 대한 비인가자의 접근통제 등 보호조치

■ 증거자료 준비사항

구분	준비사항
증거자료	• 개인정보 전송 내역을 기록하고 보관을 위한 시스템

■ 미흡 사례

사례 1	• 개인정보 전송 내역을 기록하고 보관을 확인할 수 있는 충분한 저장 공간을 갖추지 않은 경우
------	--

2.1.5 전송받은 정보의 분리·보관 기능

세부 지정요건 및 주요 확인사항	
주요내용	전송받은 정보는 기존에 보유하고 있던 정보와 분리해서 보관하도록 설비 및 시스템을 갖추어야 하고 전송받은 정보는 내부망에 안전하게 관리되도록 하여야 한다.
주요 준비사항	① 전송받은 정보와 그 외 보관하고 있는 정보를 분리·보관 하도록 설비 및 시스템을 갖추고 있는가? ② 전송받은 정보는 내부망에 보관하도록 하고 있는가?
관련 규정	개인정보 보호법 시행령 제42조의6제8항 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송받은 정보와 그 외 보관하고 있는 정보를 분리·보관하도록 설비 및 시스템을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 전송받은 정보와 자체적으로 보유하고 있는 정보에 대해서는 분리해서 보관할 수 있도록 설비 및 시스템을 갖추어야 한다.
 - 전송받은 정보와 자체적으로 보유하고 있는 정보의 분리·보관은 저장하는 DB를 물리적 또는 논리적으로 분리하여 보관
 - 정보를 보관하는 서버의 위치는 국내로 한정
- 일반수신자는 전송받은 정보에 포함된 개인정보를 처리하는 개인정보처리시스템과 자체적으로 보유하고 있는 개인정보처리시스템의 개인정보를 함께 활용하지 않도록 하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 제3자 전송 요구에 따른 전송받은 정보와 기존 보유하고 있는 개인정보의 분리 및 보관할 수 있는 설비 및 시스템 • 물리적/논리적 DB 분리 증적자료 • DB 테이블 명세서(개인정보가 포함된 테이블), 전송 요구 DB의 최신 현행화된 ERD • 전송 요구 관련 정보시스템 자산 목록

■ 미흡 사례

사례 1	• 제3자 전송 요구에 따른 전송받은 정보와 기존 보유한 개인정보를 분리하지 않고 사용하는 경우
사례 2	• 개인정보를 논리적 테이블로 분리하였으나, 접근 통제 미흡으로 기존 DB 서비스 계정으로 제3자 전송 요구에 따른 전송받은 정보가 담긴 테이블에 접근이 가능한 경우

준비사항

② 전송받은 정보는 내부망에 보관하도록 하고 있는가?

■ 세부 설명

- 전송받은 정보는 개인정보가 포함되어 있으므로 안전하게 보호하기 위해 내부망에 관리되도록 네트워크 환경을 구성하여야 한다.
 - 네트워크 대역별 IP주소 부여 기준 마련
 - 외부에서 내부 주소체계가 노출되지 않도록 사설 IP주소 체계를 사용한 NAT(Network Address Translation) 기능 적용
 - 전송받은 정보를 기반으로 내부 직원이 처리하는 업무처리 시스템과 전송받은 정보를 보유한 데이터 베이스도 내부망에 저장

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송 요구 관련 정보처리시스템 네트워크 구성도 • 제공받은 정보를 하는 시스템 및 DB 구축 현황

2.1.6 전송 내역의 중계전문기관을 통한 개인정보전송지원플랫폼 제출 기능

세부 지정요건 및 주요 확인사항	
주요내용	일반수신자의 전송 내역을 중계 전문기관에 전송할 수 있는 기능을 갖추어야 한다.
주요 준비사항	① 전송내역의 API 연계 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송내역의 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 일반수신자는 전송내역을 중계전문기관에 전송 API 연계할 수 있는 기능을 갖추어야 한다.
 - 중계 전문기관에 전송내역 전송
 - ※ 개인정보 전송지원 플랫폼은 중계 전문기관을 통해 전송내역을 전송받아 확인 가능함

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 중계전문기관에 전송내역 전송 기능

2.2 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및
보안시스템 구축

2.2.1 전송 요구 관련 시스템의 네트워크 구축

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고 방지 등 운영하는 시스템 보호가 가능한 네트워크를 구성하여야 한다.
주요 준비사항	① 전송요구 관련 시스템의 운영 및 보호가 가능한 네트워크를 구성하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송요구 관련 시스템의 운영 및 보호가 가능한 네트워크를 구성하고 있는가?

■ 세부 설명

- 전송 요구 관련 시스템으로 API 연계를 통해 처리되는 경우와 제공 받은 정보를 처리하는 경우에 대한 네트워크에 대한 보호대책 마련을 하여야 한다.
 - 네트워크에 대한 비인가 접근을 통제하기 위하여 IP관리, 불필요한 서비스 통제 등 관리절차 수립
 - 시스템 등에 IP주소 부여하고 허가되지 않은 IP사용 통제
 - 업무목적 및 중요도에 따라 네트워크 분리(DMZ, 서버팜, DB존, 개발존 등)와 접근통제 보호조치
 - 네트워크 장비에 설치된 불필요한 서비스 및 포트 차단 등 보호조치
- 전송 요구 관련 업무 처리를 위한 DMZ, 서버팜, DB존 등으로 구분하여 네트워크 환경에 대한 보호조치가 되도록 한다.
 - DMZ구간과 내부망(서버팜, DB존)에 대한 접근통제 운영 및 관리
 - ※ DMZ구간과 내부망사이에 방화벽을 설치하여 접근통제 방안 마련 고려
 - 내부망의 주소 체계는 사설 IP주소 체계를 사용하여 외부에 주소체계가 외부에 노출되지 않도록 보호조치
 - 이외에 네트워크 환경 및 정보시스템 보호를 위한 정보보호시스템 구축 및 운영
- 물리적으로 떨어진 IDC, 지사 등과의 네트워크 연결 시 전용회선 또는 VPN(가상사설망) 등을 활용하여 안전한 접속환경을 구성하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송 요구 관련 시스템 네트워크 구성도 • 네트워크 접근통제 규칙(Rule) • 정보보호 시스템 목록

2.2.2 전송 요구 관련 시스템에 대한 침입탐지·차단 시스템 구축

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 침입차단·탐지 시스템을 설치 운영하도록 하여야 한다.
주요 준비사항	① 정보통신망을 통한 불법적인 접근방지를 위한 침입차단시스템, 침입탐지 시스템 등 보호설비 또는 기술을 갖추고 있는가? ② 시스템 및 업무용 컴퓨터에 대한 이동식 저장 매체 통제, 바이러스 및 스파이웨어 탐지 등을 위한 보안프로그램을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 정보통신망을 통한 불법적인 접근방지를 위한 침입차단시스템, 침입탐지시스템 등 보호설비 또는 기술을 적용하고 있는가?

■ 세부 설명

- 정보통신망을 통한 불법적인 접근 및 침해사고를 방지하기 위해 아래의 기능을 포함한 안전조치를 하여야 한다.
 - 접근권한을 IP 주소, 포트, MAC 주소 등으로 제한하여 인가받지 않은 접근을 제한할 수 있는 침입 차단시스템(방화벽), 침입탐지 및 차단시스템(IDS, IPS), UTM 등 보호설비 설치 및 운영
 - 전송 요구 관련 시스템을 위한 방화벽 접근통제 정책 수행
 - 침입차단시스템 등에 대한 최신 시그니처 및 패턴 업데이트를 통한 최신화 유지
 - 이외에 필요시 추가적인 침해사고 방지를 위한 보호설비 또는 기술 적용(예, 서버웹 쉘 모니터링 적용 등)
- ※ 클라우드서비스를 이용하는 경우, 클라우드서비스제공자가 제공하는 보안기능 또는 서비스를 이용하여 접근통제 기능 구현 적용

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 방화벽, IPS or IDS, UTM 등 정보보호시스템 목록(예, 자산관리대장) • 네트워크 상세 구성도 (방화벽, IPS 등 침입차단시스템 중심)

■ 미흡 사례

사례 1	• 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 정보보호시스템이 구축되지 않은 경우
사례 2	• 침입방지시스템(IPS 등) 등 보안솔루션이 시그니처(패턴)를 주기적으로 최신 패턴으로 업데이트하지 않은 경우

준비사항

② 시스템 및 업무용 컴퓨터에 대한 이동식 저장매체 통제, 바이러스 및 스파이웨어 탐지 등을 위한 보안프로그램을 갖추고 있는가?

세부 설명

- 전송요구 관련 시스템 및 업무용 컴퓨터 등에 대하여 이동식 저장매체 통제, 백신 소프트웨어 설치 등 보호조치를 하여야 한다.
 - 이동식 저장매체 읽기, 쓰기 통제를 위한 정보보호시스템 또는 기술 적용
 - 이동식 저장매체를 사용할 경우, 내부 정책을 수립하여 책임자 승인절차를 통해 제한적으로 사용하도록 통제
 - 바이러스, 스파이웨어, 웜, 트로이목마, 랜섬웨어 등 악성코드로부터 보호할 수 있는 보안프로그램 설치 및 운영
 - ※ 보안프로그램의 경우 운영체제에서 제공하여 자동으로 설치된 프로그램(예, Windows Defender)도 가능함
 - ※ 클라우드 환경의 경우 클라우드 서비스에서 제공된 보안프로그램 설치 및 운영
 - 보안프로그램은 업데이트 등을 통해 최신상태 유지

증적자료 준비사항

구분	준비사항
증적자료(예시)	• 이동식 저장매체 통제, 백신 소프트웨어 등 정보보호시스템 목록(예. 자산관리대장) • 백신 프로그램 설치 범위 (전송 요구 관련 시스템은 모두 포함, 업무용 컴퓨터 등)

미흡 사례

사례 1	• 전송요구 관련 시스템 및 해당 업무 담당자 컴퓨터에 백신 프로그램이 설치되어 있지 않은 경우
사례 2	• 백신 엔진이 장기간 최신 버전으로 업데이트되지 않은 경우
사례3	• 전송요구 관련 시스템 및 해당 업무 담당자 컴퓨터에 악성코드 감염 이력이 확인되었으나, 감염 경로 및 바이러스 감염 원인 분석 후 재발 방지 대책 등 구체적인 조치 활동을 수행하지 않은 경우

3 보호체계

3.1. 일반수신자 업무 관련 정보의 안전성 확보를 위한 내부 관리계획

※ 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함

세부 지정요건 및 주요 확인사항	
주요내용	일반수신자 업무 관련 정보의 안전성 확보를 위한 보호 정책을 수립하여야 한다. 보호 정책 수립 시, 「개인정보의 안전성 확보조치 기준(개인정보보호위원회고시 제2023-6호)」 제4조에 규정된 내부 관리계획의 기재사항을 포함하여 해킹 등 전자적 침해행위로부터 보호하기 위한 내용 및 일반수신자 업무를 반영한 내용 등을 포함하여 작성하여야 한다.
주요 준비사항	① 일반수신자 업무 관련 정보의 안전성 확보를 위한 내부 관리계획을 수립·시행하고 있는가? ② 내부 관리계획 이행 실태 점검을 수행하고 있는가? ③ 침해사고의 정의 및 범위, 긴급연락체계 구축, 침해사고 대응 모니터링, 침해사고 발생 시 보고 및 대응절차, 침해사고 대응조직의 구성 등을 포함한 침해사고 대응체계를 수립하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시 개인정보 보호법 제34조(개인정보의 유출 등의 통지·신고)

준비사항

① 일반수신자 업무 관련 정보의 안전성 확보를 위한 내부 관리계획을 수립·시행하고 있는가?

■ 세부 설명

- 일반수신자 업무 관련 정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 일반수신자 업무 특성을 반영한 내부 관리계획을 수립·시행하여야 한다.

※ 기업(기관)에서 수립된 내부 관리계획에 일반수신자 업무 관련 내용을 추가 작성하거나 별도의 지침, 절차서를 둘 수 있음

- 일반수신자 업무 수행 조직의 구성 및 운영에 관한 사항

- 일반수신자 업무 관리책임자의 지정에 관한 사항

※ 관리책임자는 일반수신자 운영 및 업무를 총괄하여 책임을 가진 자를 말함

- 일반수신자 업무 관리책임자와 개인정보취급자의 역할 및 책임에 관한 사항

- 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항

- 접근 권한의 관리에 관한 사항

- 접근 통제에 관한 사항

※ 전송요구 관련 시스템에 대해 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 접근통제에 관한 사항 포함

※ 전송요구 관련 시스템과 기업(기관)에서 운영하고 있는 시스템과 분리하여 운영해야 하므로 이에 대한 접근 통제 및 보호조치 방안 포함

- 개인정보의 암호화 조치에 관한 사항

- 접속기록 보관 및 점검에 관한 사항

- 악성프로그램 등 방지에 관한 사항

- 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항

- 물리적 안전조치에 관한 사항

- 파기에 관한 사항

※ 파기대상을 누락없이 작성하고 파기 시기 및 방법·절차를 구체적으로 작성하여 파기 수행이 제대로 될 수 있도록 작성

※ 파기대상으로 전송요구서, 폐기된 접근토큰, 3년이 경과된 전송내역 정보 및 개인정보는 반드시 포함되어야 함

- 개인정보 유출사고 대응 계획 수립·시행에 관한 사항

※ 개인정보 유출통지, 유출신고 등 유출사고 대응을 위한 구체적인 내용을 작성하여야 함. 별도의 지침, 절차서를 둘 수 있음

- 위험 분석 및 관리에 관한 사항

- 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항

- 내부 관리계획의 수립, 변경 및 승인에 관한 사항
 - 그 밖에 전송요구 업무 관련 정보의 안전성 확보를 위하여 필요한 사항
- 수립된 내부 관리계획의 중요한 변경이 있는 경우에는 이를 즉시 반영하여 시행하고, 그 수정 이력을 관리하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 운영관리 정책(내부 관리계획, 지침, 절차서, 매뉴얼 등)

■ 미흡 사례

사례 1	• 내부 관리계획을 수립하지 않은 경우
사례 2	• 내부 관리계획에서 일부 중요 항목이 누락되거나 최근 개정된 관계 법령이 반영되지 않은 경우

준비사항

② 내부 관리계획 이행 실태 점검을 수행하고 있는가?

■ 세부 설명

- 전송요구 관련 시스템에 대한 내부 관리계획의 이행 실태를 연 1회 이상 점검 · 관리하여야 한다.
 - 내부 관리계획 내 작성된 내용을 점검항목으로 식별하고, 각 항목의 이행 여부를 점검하여야 함
 - 이행 실태 점검은 내부 관리계획에 따른 기술적, 관리적 및 물리적 안전조치 사항에 대하여 누락없이 점검 및 관리되도록 해야 함
 - 이행 실태 점검 결과에 따른 미흡사항에 대하여 개선 조치를 수행해야 함
- ※ 전송요구 관련 시스템이 운영되기 전일 경우 이행 실태 점검은 계획서로 대체
- 내부 관리계획 이행 실태 점검 결과에 대해 전문기관 관리책임자에게 보고하고, 이에 대해 개인정보 보호 책임자(CPO)는 제대로 수행되고 있는지에 대하여 관리·감독하도록 하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획 이행 실태 점검표 • 전문기관 관리책임자 검토 및 승인 결과 • 이행 실태 점검 계획(시스템 운영되기 전일 경우)

■ 미흡 사례

사례 1	• 일반수신자 관리책임자의 개인정보 내부 관리계획 검토 이력이 존재하지 않은 경우
------	---

준비사항

- ③ 침해사고의 정의 및 범위, 긴급연락체계 구축, 침해사고 대응 모니터링, 침해사고 발생 시 보고 및 대응절차, 침해사고 대응조직의 구성 등을 포함한 침해사고 대응체계를 수립하고 있는가?

■ 세부 설명

- 서비스 관련 주요 데이터의 유출, 장애 및 침해 등의 사고 발생 시 조직의 업무에 미치는 영향을 고려하여 식별된 정보자산의 중요도를 평가하고 신속하게 대응하기 위해 아래의 내용을 포함하여 절차를 수립하여야 한다.
 - 침해사고의 정의 및 범위 (중요도 및 유형 포함)
 - 침해사고 발생 시 기록, 보고 절차
 - 비상연락체계
 - 침해사고 신고 및 통지 절차 (관계기관, 외부전문가, 이용자 등)
 - 침해사고 유형에 따른 대응 절차 (대응조직 구성 및 구성원의 역할과 책임 포함)
 - 침해사고 복구조직의 구성, 책임 및 역할
 - 침해사고 대응 및 복구 훈련, 훈련 시나리오
 - 침해사고 훈련 결과 검토 후 개선 방안을 침해사고 대응 절차에 반영
- 침해사고를 모니터링하고 종합적인 대응을 위한 체계를 수립하여야 한다.
 - 모니터링 및 대응 방법, 절차
 - 대응 조직 및 인력
 - 침해사고 보고 및 승인 절차
- 보안관제서비스 등 외부 기관을 통하여 침해사고 대응체계를 구축·운영하는 경우 침해사고 대응절차의 세부사항을 계약서(SLA 등)에 반영하여야 한다.
 - 보안관제 용역의 범위
 - 침해 징후 발견 및 침해사고 발생 시 보고 및 대응 절차
 - 침해사고 발생에 따른 책임 및 역할에 관한 사항 등
- 침해사고의 모니터링, 대응 및 처리와 관련된 외부전문가, 전문 업체, 전문기관(KISA) 등과의 연락 및 협조체계를 수립하여야 한다.
 - 외부 전문기관과의 비상연락망 유지 등 연락체계를 구축하고 담당자, 연락처 등의 정보를 최신으로 유지
 - 자체 긴급연락망 등을 수립
 - 침해사고 발생 시 관련 책임자들에게 핫라인 등을 통해 즉각 통지 절차 마련

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 침해사고 관리지침(대응절차, 대응조직 포함) • 침해사고 대응조직 및 비상연락망(외부기관 포함) • 보안관제 용역 계약서 및 SLA(용역 계약을 한 경우에 한함) • 보안 관제 보고서

■ 미흡 사례

사례 1	• 침해사고에 대비한 침해사고 대응 조직 및 대응 절차를 명확히 정의하고 있지 않은 경우
사례 2	• 외부 보안관제 전문업체 등 유관기관에 침해사고 탐지 및 대응을 위탁하여 운영하고 있으나, 침해 사고 대응에 대한 상호 간 관련 역할 및 책임 범위가 계약서나 SLA에 명확하게 정의되지 않은 경우
사례 3	• 침해사고 신고·통지 및 대응 협조를 위한 대외기관 연락처에 기관명, 홈페이지, 연락처 등이 잘못 명시되어 있거나, 일부 기관 관련 정보가 누락 또는 현행화되지 않은 경우

3.2 개인정보 전송 이력 기록·보관 및 점검 방안

세부 지정요건 및 주요 확인사항	
주요내용	개인정보 전송 내역에 대한 기록이 3년간 안전하게 보관되도록 하여야하고 전송 내역에 대해서는 주기적으로 점검하여야 한다.
주요 준비사항	① 개인정보 전송 내역을 안전하게 보관하고 있는가? ② 개인정보 전송 내역을 주기적으로 점검하고 있는가?
관련 규정	개인정보보호법 시행령 제42조의6(개인정보 전송의 기한 및 방법 등) 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보 전송 내역을 안전하게 보관하고 있는가?

■ 세부 설명

- 다음 항목의 개인정보 전송 내역을 3년간 보관하여야 한다.

- 정보주체가 전송요구 시 특정하는 사항

- 전송 요구 목적
- 전송 요구를 받는 자
- 개인정보를 전송받는 자
- 전송을 요구하는 개인정보
- 정기적 전송을 요구하는지 여부 및 요구하는 경우 그 주기
- 전송 요구의 종료시점
- 전송을 요구하는 개인정보의 보유 및 이용기간

- 정보주체의 전송 요구에 따른 정보 송·수신 기록

- 전송 요구의 철회, 전송 요구 거절 및 전송 중단 내역 및 사유

※ 업무를 위해 전송을 받기 전에는 전송 내역 기록은 없으므로 전송 내역 기록할 수 있는 기능 및 3년간 보관할 수 있는 저장 공간을 확인하는 것으로 대체

- 개인정보 전송 내역이 위·변조 및 도난, 분실되지 않도록 다음 방법 중 어느 하나를 고려하여 안전하게 보관하여야 한다.

- 정기적으로 개인정보 전송 내역 백업 수행 및 별도의 저장장치에 보관

- CD-ROM, WORM(Write Once Read Many) 등 덮어쓰기 방지 매체 사용

- 개인정보 전송 내역을 수정 가능한 매체(하드디스크, 자기 테이프 등)에 백업하는 경우에는 무결성 보장을 위해 위·변조 여부를 확인할 수 있는 정보(MAC값, 전자서명값 등)를 별도의 장비에 보관·관리 등

- 개인정보 전송 내역에 대한 접근 권한 부여는 최소화하여 비인가자에 의한 위·변조 및 삭제 등이 발생하지 않도록 하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 전송 요구서 • 개인정보 전송 내역 • 개인정보 전송 내역 저장장치에 대한 접근통제 내역

■ 미흡 사례

사례 1	• 개인정보 전송 내역을 DBMS에 테이블로 저장하고 있으나, 접근 계정을 통제하지 않아 업무와 관련없는 비인가자도 접근이 가능한 경우
------	---

준비사항

② 개인정보 전송 내역을 주기적으로 점검하고 있는가?

■ 세부 설명

- 개인정보 전송 내역의 위·변조, 유·노출, 오류 등에 대응하기 위하여 점검 계획을 수립하고, 그 계획에 따라 주기적(월 1회 이상)으로 점검하여야 한다.
 - 점검계획에는 점검 방법, 점검 기준, 점검 주기/시점, 담당자, 이상 발견 시 대응 절차, 보고 절차 등 포함
 - ※ 전송요구 관련 시스템이 운영되기 이전에는 개인정보 전송 내역 점검 계획서로 대체
- 개인정보 전송 내역 점검 결과는 책임자에게 보고하고 이상징후 발견 시 절차에 따라 대응하여야 한다.
 - 개인정보 전송 내역 점검 결과 및 이상징후 발견 여부 등 그 결과를 책임자에게 보고
 - 이상징후 발견 시 개인정보 전송 내역 오류 등 발생 여부를 확인하기 위한 절차를 수립하고 절차에 따라 대응

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보 전송 내역 점검 절차 및 결과 • 개인정보 전송 내역 점검 계획서(전송요구 관련 시스템 운영 전일 경우)

■ 미흡 사례

사례 1	• 개인정보 전송 내역 점검 계획이 수립되어 있지 않고, 주기적인 점검결과 증적자료가 없는 경우
------	---

3.3 전송 요구 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근권한의 관리 및 점검 체계

세부 지정요건 및 주요 확인사항	
주요내용	개인정보취급자 및 관리자의 접근권한을 관리하고 주기적으로 점검하여 안전하게 처리되도록 하여야 한다.
주요 준비사항	① 개인정보취급자의 업무상 필요한 최소한의 권한만을 부여하고 있는가? ② 개인정보취급자별로 계정을 발급하고 다른 개인정보취급자와 공유하지 않도록 하고 있는가? ③ 관리자 권한 및 특수권한을 식별하여 최소한의 인원에게 부여하고 있는가? ④ 시스템에 대한 접근권한 부여·변경·말소에 대한 내역을 기록하고 보관하고 있는가? ⑤ 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하고 있는가? ⑥ 정당한권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정횟수 이상 인증에 실패한 경우 시스템에 대한접근을 제한하는 등 필요한 조치를 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보취급자의 업무상 필요한 최소한의 권한만을 부여하고 있는가?

■ 세부 설명

- 전송요구 관련 시스템에 개인정보취급자(수탁자 포함)의 계정 생성 및 변경 시 수립된 접근권한 분류체계에 따라 최소한의 권한만 부여하여야 한다.
 - 정보시스템에 대하여 중요 디렉토리 및 파일을 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여
 - 데이터베이스에 대하여 중요 객체를 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여
 - 응용프로그램에 대하여 주요 메뉴 및 기능을 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자(수탁자 포함) 목록 • 정보시스템 계정 및 권한 관리 대장 또는 화면 • 데이터베이스 계정 및 권한 관리 대장 또는 화면 • 응용프로그램 계정 및 권한 관리 대장 또는 화면

■ 미흡 사례

사례 1	• 수탁사 직원인 개인정보취급자에게 정보시스템에 접근권한을 과도하게 부여하여 백업 디렉토리 또는 중요 설정/로그/key 파일에 접근 가능한 경우
------	--

준비사항

② 개인정보취급자별로 계정을 발급하고 다른 개인정보취급자와 공유하지 않도록 하고 있는가?

■ 세부 설명

- 전송요구 관련 시스템에 대한 계정 발급은 개인정보취급자별로 유일하게 구분할 수 있는 식별자를 할당하여야 한다.
 - 개인정보취급자별로 고유한 사용자 계정 발급을 원칙으로 하여 사용자에게 대한 책임추적성 확보
 - 계정 공유 금지 및 공용 계정 사용 제한
- 업무상 불가피하게 동일한 식별자를 공유하여 사용하는 경우 그 사유와 타당성을 검토하고 관리책임자의 승인을 받도록 하고 계정 관리 대장, 접근제어 시스템 도입 등 관리적 또는 기술적 보완통제를 통해 접속한 자를 식별할 수 있도록 하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자(수탁자 포함) 목록 • 전송요구 관련 시스템 개인정보취급자 계정 목록

■ 미흡 사례

사례 1	• 수탁사 직원이 일반수신자 직원과 동일 계정을 공유하여 사용하고 있는 경우
------	--

준비사항

③ 관리자 권한 및 특수 권한을 식별하여 최소한의 인원에게 부여하고 있는가?

■ 세부 설명

- 관리자 및 특수 권한은 최소한의 인원에게만 부여하여야 한다.
 - 관리자 및 특수 권한은 공식적인 신청 절차를 통해 관리책임자의 승인 절차에 따라 부여
 - 특히, 서버 운영자, DB 운영자, 응용프로그램 관리자, 정보보호시스템 운영자 등에 대한 계정은 최소 인원으로 부여
 - 관리자 및 특수 권한은 최소한의 업무 수행자에게만 부여할 수 있도록 일반 사용자 계정, 권한 발급 절차 보다 엄격한 기준 적용
- ※ 특수목적에 위한 계정 및 권한을 가지는 특수 권한 예시는 아래와 같음

- 관리자 권한(Root, Administrator, admin, sys, system, sa 등 최상위 권한)
- 배치프로그램 실행을 위하여 부여된 권한
- 정보보호 시스템 관리자 권한
- 계정 생성 및 접근권한을 설정할 수 있는 권한 등

- 특수 목적을 위하여 부여한 계정 및 권한을 식별하고 별도의 목록으로 관리하는 등 통제절차를 수립·이행하여야 한다.
 - 관리자 및 특수 권한 목록 작성 관리
 - 관리자 및 특수 권한 모니터링 강화 등의 통제절차 수립·이행
 - 정보시스템 유지보수 등 외부자에게 부여하는 관리자 및 특수 권한은 필요시에만 생성, 업무 종료 후에는 즉시 삭제 또는 정지하는 절차를 적용
 - 관리자 및 특수 권한 계정 현황을 정기적으로 검토하여 목록 현행화

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 관리자 및 특수 권한 신청·승인 내역 • 관리자 및 특수 권한 계정 목록

■ 미흡 사례

사례 1	• 관리자 및 특수 권한이 명확히 정의되지 않아, 일부 계정에 특수 권한(계정 생성, 개인정보 파기 권한 등)이 부여된 경우
사례 2	• 시스템에 등록된 관리자 계정 중 일부의 계정의 발급 신청서를 찾을 수 없는 경우
사례 3	• 퇴직하거나 전보된 관리자의 계정이 존재하는 경우
사례 4	• 유지보수 업체 직원이 분기 1회 방문하고 있지만, 유지보수를 위한 유지보수용 관리자 계정이 상시 활성화되어 있음

준비사항

④ 시스템에 대한 접근권한 부여·변경·말소에 대한 내역을 기록하고 보관하고 있는가?

■ 세부 설명

- 전송요구 관련 시스템에 대한 접근권한을 부여, 변경 또는 말소한 내역은 책임추적성을 확보할 수 있도록 관련 사항이 모두 포함되어 기록되어야 한다.
 - 대상자 정보(식별자 등)
 - 접근권한 부여자 정보(담당자, 승인자 등)
 - 접근권한 정보(일시, 권한명, 사유 등)
 - 기타 접근권한 검토를 위해 필요한 정보(특이사항 등)
- 접근권한 내역은 최소 3년간 보관하여야 한다.
 - ※ 전송요구 관련 시스템 운영되기 전일 경우는 3년간 보관할 수 있도록 구현한 기능으로 대체
 - ※ 전송요구 관련 시스템 운영이 3년이 경과되지 않은 경우는 현재까지 기록된 접근권한 내역 확인
- 접근권한 내역은 위·변조 또는 도난, 분실되지 않도록 안전하게 보관하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 시스템 접근권한 부여·변경·말소 내역

■ 미흡 사례

사례 1	• 전송요구 관련 시스템의 접근권한 내역은 로그 테이블에 저장되어 보관되고 있으나, 일부 항목이 누락되어 있어 누가 승인 하였는지 등의 정보를 파악하기 어려운 경우
사례 2	• 전송요구 관련 시스템을 운영한지 3년이 경과하였으나, 접근권한 내역은 2년만 보관하고 있는 경우

준비사항

⑤ 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하고 있는가?

■ 세부 설명

- 정당한 권한을 가진 개인정보취급자 또는 정보주체를 인증하기 위하여 개인정보 처리환경, 침해위험, 정보주체에 미치는 영향 등을 고려하여 인증수단을 안전하게 적용하고 관리하여야 한다.

- 인증 수단 예시

인증수단 유형	인증수단 예
지식 기반	비밀번호 등
소유 기반	인증서(PKI), OTP, 스마트 카드, 보안 토큰 등
생체 기반	지문, 홍채, 안면 등

- 비밀번호를 인증수단으로 적용하는 경우, 개인정보취급자 또는 정보주체가 안전한 비밀번호를 설정하여 이행할 수 있도록 비밀번호 작성규칙을 수립하고 이를 전송요구 관련 시스템 및 정보보호시스템 등에 적용하여야 한다.
- 비밀번호 이외의 인증수단을 적용하는 경우, 해당 인증수단의 발급, 배포, 설정, 보관, 변경, 폐기 등의 과정에서 유·노출 되거나 도용되지 않도록 안전한 관리 방안 및 절차를 수립·적용하여야 한다.
- 관리자 및 특수 권한 계정 인증, 중요 정보/기능 접근 시 인증 등의 경우 안전한 인증수단(예, 다중요소 인증(MFA, Multi-Factor Authentication))을 적용하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자 또는 정보주체 로그인 화면 • 비밀번호 작성 규칙 • 인증서(PKI) 관리 절차 • 정보서비스 흐름도

■ 미흡 사례

사례 1	• 비밀번호 관련 내부 규정에는 비밀번호를 초기화 시 임시 비밀번호를 부여받고 강제적으로 변경하도록 되어 있으나, 실제로는 임시 비밀번호를 그대로 사용하고 있는 경우
------	--

준비사항

- ⑥ 정당한 권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 시스템에 대한 접근을 제한하는 등 필요한 조치를 하고 있는가?

■ 세부 설명

- 정당한 권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 시스템에 대한 접근을 제한하는 등 필요한 조치를 취하여야 한다.
 - 로그인 화면에서 연속적으로 일정 횟수(예를 들어, 5회) 이상 인증 실패 시 시스템 접속을 차단
 - 시스템 관리자는 개인정보취급자 확인 후 접속 차단 해제하거나, 강화된 인증수단(예, 소유 또는 생체 기반)을 적용 후 접속 차단 해제

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자 연속 인증 실패 시 잠금 기능 • 시스템 접속 차단 해제 절차

■ 미흡 사례

사례 1	• 개인정보취급자 로그인 화면에 “비밀번호 3회 입력 오류 시 로그인 접속이 제한됩니다”라는 메시지는 기재되어 있으나, 실질적으로 차단되도록 구현되어 있지 않은 경우
------	--

3.4 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 전송 요구 관련

시스템, 업무용 단말 등에 대한 접근통제 체계

3.4.1 전송 요구 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 전송 요구 관련 시스템 및 업무용 컴퓨터에 대한 유해사이트 차단 등 접근통제와 관련된 보호 조치를 하여야 한다.
주요 준비사항	① 접근통제 정책에 따라 인가된 사용자만이 내부 네트워크에 접근할 수 있도록 인터넷 프로토콜(IP) 주소 등을 통제하고 있는가? ② 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있도록 정보보호 시스템을 구축하여 운영하고 있는가? ③ 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 전송요구 처리 정보가 공개되거나 유출되지 않도록 시스템, 컴퓨터 및 모바일 기기 등에 조치하고 있는가? ④ 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 접근통제 정책에 따라 인가된 사용자만이 내부 네트워크에 접근할 수 있도록 인터넷 프로토콜(IP) 주소 등을 통제하고 있는가?

■ 세부 설명

- 네트워크 대역별 IP주소 부여 기준을 마련하고 데이터베이스, 서버 등 중요 시스템을 사설 IP로 할당하여 외부에서 직접 접근이 불가능하도록 방화벽 등을 활용하여 설정하여야 한다.
 - IP주소 할당 현황을 최신으로 유지하고 IP주소 관리대장은 안전하게 관리
 - 내부망의 주소 체계는 사설 IP주소 체계를 사용하고 외부에 내부 주소체계가 노출되지 않도록 NAT(Network Address Translation) 기능 적용
 - 인가된 사용자만 네트워크에 접근할 수 있도록 IP 통제
 - 네트워크 장치에 불필요한 서비스 및 포트 등 제거 또는 차단
- 물리적으로 떨어진 IDC, 지사 등과의 네트워크 연결 시 전용회선 또는 VPN(가상사설망) 등을 활용하여 안전한 접속환경을 구성하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성 • IP 관리 대장 • 정보자산 목록

■ 미흡 사례

사례 1	• IP관리대장 및 정보자산목록을 주기적으로 점검하여 현행화하지 않아 실제 구축된 시스템의 IP내용과 일치하지 않은 경우
------	---

준비사항

② 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있도록 정보보호시스템을 구축하여 운영하고 있는가?

■ 세부 설명

- 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있는 정보보호시스템을 설치하여 운영하여야 한다.
- 전송요구 관련 시스템의 중요 정보를 보호하기 위한 정보보호시스템에 대하여 다음 내용을 포함한 운영 절차를 수립·이행하여야 한다.
 - 정보보호시스템 정책(룰셋 등) 적용 절차
 - 정보보호시스템별 책임자 및 관리자 지정
 - 최신 정책 업데이트 방안
- ※ IPS, 웹방화벽 등의 정보보호시스템의 경우, 새로운 공격기법을 탐지하기 위한 최신 패턴(시그니처) 및 엔진의 지속적 업데이트 수행
- 정보보호시스템 이벤트 모니터링 절차(정책에 위배되는 이상징후 탐지 및 확인 등)
- 정보보호시스템 접근통제 정책
- 정보보호시스템 운영현황의 주기적 점검 등
- ※ 정보보호시스템 유형은 다음과 같음

- 네트워크 정보보호시스템 : 침입차단시스템(방화벽), 침입방지시스템(IPS), 침입탐지시스템(IDS), 네트워크 접근제어(NAC), DDoS대응시스템, 가상사설망(VPN) 등
- 서버 정보보호시스템 : 서버 접근제어, 보안운영체제(Secure OS)
- DB 정보보호시스템 : DB 접근제어
- 정보유출방지시스템 : N-DLP(Network Data Loss Prevention), E-DLP(Endpoint Data Loss Prevention) 등
- 기타 : APT 대응 솔루션, 웹방화벽 등

- 정보보호시스템 관리자 등 접근이 허용된 인원을 최소화하고 비인가자의 접근을 엄격하게 통제하여야 한다.
- 정보보호시스템 정책의 신규 등록, 변경, 삭제 등을 위한 공식적인 절차를 수립·이행하여야 한다.
- 정보보호시스템에 설정된 정책의 타당성 여부에 대하여 주기적으로 검토하여야 한다.

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 정보보호시스템별 관리 화면(IDS, IPS, 웹방화벽 등) • 침입탐지 엔진 및 패턴 업데이트 이력

■ 미흡 사례

사례 1	• 정보 유출을 탐지 및 차단하고 있는 IPS를 확인한 결과, 탐지 엔진 및 탐지 패턴이 주기적으로 업데이트 되지 않아 최근 발생한 유출 시도가 탐지되지 않고 있는 경우
------	--

준비사항

- ③ 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 전송요구 처리 정보가 공개되거나 유출되지 않도록 시스템, 컴퓨터 및 모바일 기기 등에 조치하고 있는가?

■ 세부 설명

- 전송요구 처리 중인 정보가 인터넷 홈페이지, P2P, 공유설정, 공개된 무선망 이용 등을 통하여 열람 권한이 없는 자에게 공개되거나 유출되지 않도록 시스템, 개인정보취급자 컴퓨터, 모바일기기 등에 조치를 하여야 한다.

- 전송요구 처리 중인 정보가 인터넷 홈페이지를 통해 열람권한이 없는 자에게 공개되거나 유출되지 않도록 다음과 같은 항목 등을 고려하여 조치

※ 인터넷 홈페이지를 통한 정보 유·노출 방지 대책에 관한 내용은 아래와 같음

- 잘 알려진 웹 취약점 항목들을 포함한 웹 취약점 점검 및 조치
- 인터넷 홈페이지 중 서비스 제공에 사용되지 않거나 관리되지 않는 사이트 또는 URL에 대한 삭제 또는 차단 조치
- 인터넷 홈페이지 관리자 페이지에 대한 노출 차단 등의 보호조치
- 웹 방화벽 설치·운영을 통하여 웹 해킹을 통한 개인정보 유·노출 탐지 및 차단
- 개인정보 필터링 솔루션을 통하여 게시판, 첨부파일 등을 통해 노출된 개인정보 탐지 및 변환
- 웹 취약점 점검과 함께 정기적으로 웹 쉘 등을 점검하고 조치하는 경우 취급중인 개인정보가 인터넷 홈페이지를 통해 열람권한이 없는 자에게 공개되거나 유출되는 위험성을 더욱 줄일 수 있음
- 시스템에서 인터넷으로의 아웃바운드 접속 차단(필요 시 해당 IP, Port만 허용) 등

- 전송요구 처리 정보가 개인정보취급자의 업무용 컴퓨터, 모바일 기기 등을 통해 열람권한이 없는 자에게 공개되거나 유출되지 않도록 다음과 같은 항목 등을 고려하여 조치

※ 개인정보취급자의 컴퓨터 또는 모바일기기를 통한 정보 유·노출 방지대책에 관한 내용은 아래와 같음

- N-DLP(Network Data Loss Prevention), 비업무사이트 차단시스템 등 보안시스템을 도입하여 개인정보의 외부전송 모니터링 및 P2P, 웹하드 등 개인정보 유·노출 위험성이 높은 사이트 차단 조치
- PC보안, E-DLP(Endpoint Data Loss Prevention) 등 업무용 컴퓨터에 보안프로그램을 설치하여 공유폴더 설정 차단, 메신저, P2P 및 웹하드 프로그램 실행차단, 매체 제어 등 조치
- 개인정보 송·수신 시 SSL, VPN 등 보안기술이 적용된 전용 프로그램을 사용하여 송·수신 또는 암호화 송·수신
- 개인정보취급자 컴퓨터, 모바일 기기에서 개인정보가 포함된 파일 송·수신 시 암호화 저장 후 송·수신

- 시스템, 개인정보취급자 컴퓨터, 모바일 기기 등에 P2P, 공유설정은 기본적으로 사용하지 않는 것이 원칙이나, 업무상 반드시 필요한 경우에는 권한 설정 등의 조치를 통해 권한이 있는 자만 접근할 수 있도록 설정하여 개인정보가 열람권한이 없는 자에게 공개되거나 유출되지 않도록 접근 통제 등에 관한 안전조치
- ※ P2P, 공유설정을 통한 정보 유·노출 방지대책에 관한 내용은 아래와 같음

- 업무상 꼭 필요한 경우라도 드라이브 전체 또는 불필요한 폴더가 공유되지 않도록 조치하고, 공유폴더에 개인정보 파일이 포함되지 않도록 정기적으로 점검
- 상용 웹메일, 웹하드, 메신저, SNS 서비스 등을 통하여 고의 혹은 부주의로 인한 정보 유·노출 방지 조치 등

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 정보보호시스템 목록 • 인터넷 홈페이지, P2P 차단 등 보호조치 현황 • 시스템 및 컴퓨터 대상 공유설정 차단 등 보호조치 현황 • 보안점검 결과(인터넷 홈페이지, 개인정보취급자 컴퓨터, 모바일 기기)

■ 미흡 사례

사례 1	• 개인정보취급자 컴퓨터의 공유폴더 사용을 금지하고 있으나, 이에 대한 주기적인 점검이 이루어지고 있지 않아 다수의 개인정보취급자 컴퓨터에서 과도하게 공유폴더를 설정하여 사용하고 있는 경우
------	---

준비사항

- ④ 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무 처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하고 있는가?

■ 세부 설명

- 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무 처리를 하지 않은 경우 자동으로 접속이 차단되도록 하여야 한다.
 - 접속차단 조치는 시스템과 개인정보취급자의 컴퓨터 등의 연결이 완전히 차단되어 정보의 송·수신이 불가능한 상태가 되어야 하며, 접속차단 조치 이후에 다시 접속하고자 할 때에는 최초의 로그인 방법과 동일한 방법으로 접속하도록 조치
 - ※ 시스템은 응용프로그램, 서버, DBMS를 모두 포함
 - 접속차단을 적용하기 위한 시간 기준은 개인정보를 처리하는 방법 및 환경, 보안위험 요인, 업무특성 (DB 운영 관리, 시스템 모니터링, 유지보수 등)을 고려하여 필요 최소한의 시간으로 설정

■ 증거자료 준비사항

구분	준비사항
증적자료(예시)	• 서버/DBMS/응용프로그램 세션 타임 허용 여부 내역

■ 미흡 사례

사례 1	• 서버 운영체제 설정을 확인 결과 세션 타임아웃 설정이 되어있지 않은 경우
------	--

3.4.2 전송 요구 관련 시스템에 대한 외부 접속 시 안전한 인증수단 등의 적용

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통해 외부에서 전송 요구 관련 시스템에 접속하려는 경우 안전한 인증수단 등 접근통제와 관련된 보호조치를 하여야 한다.
주요 준비사항	① 개인정보취급자가 정보통신망을 통해 외부에서 시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항
① 개인정보취급자가 정보통신망을 통해 외부에서 시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있는가?

■ 세부 설명

- 인터넷구간 등 외부로부터 시스템에 대한 접속은 원칙적으로 차단하여야 하나, 업무 특성 또는 필요에 의해 개인정보취급자가 노트북, 업무용 컴퓨터, 모바일 기기 등으로 외부에서 정보통신망을 통해 시스템에 접속이 필요한 경우에는 안전한 인증수단을 적용하여야 한다.
 - 안전한 인증 수단 : 인증서(PKI), 보안토큰, 일회용 비밀번호(OTP), 생체인증 등

■ 증적자료 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성도 • 인증수단 화면

■ 미흡 사례

사례 1	• 원격운영관리를 위하여 VPN을 구축하여 운영하고 있으나, VPN 접속 시 비밀번호 인증만 적용된 경우
------	--



I

부 록

일반수신자 등록 Q&A

FAQ 일반

Q1 | 일반수신자는 반드시 개인정보 전송 지원 플랫폼에 등재를 해야 하나요?

답변 : 개인정보 전송 지원 플랫폼은 정보주체의 개인정보 전송 요구·철회 내역을 관리하게 되므로 해당 기능을 연계하고 정보전송자와 일반수신자 간에 표준화된 방식으로 개인정보를 송·수신할 수 있도록 일반수신자는 개인정보 전송지원 플랫폼에 등재하여야 합니다 (시행령 제42조의16제1항).

FAQ 등재절차

Q1 | 일반수신자 등재 신청이 되지 않으면 신청기관은 해당 내용을 개선해 다시 신청할 수 있나요?

답변 : 일반수신자 등재 신청이 되지 않으면 신청기관은 해당 내용을 개선하여 다시 신청할 수 있습니다.

FAQ 등재요건

Q1 | 일반수신자로 확인받은 자는 개인정보 보호법 제29조에 따른 안전조치의무를 준수하여야 하나요?

답변 : 일반수신자로 개인정보 전송지원 플랫폼에 등재된 자 역시 개인정보처리자에 해당 하므로 개인정보 보호법 제29조에 따른 안전조치의무를 준수하여야 합니다.

발 행 일	2025년 03월
발 행 처	개인정보보호위원회
지원기관	한국인터넷진흥원

※ 최신자료는 “개인정보보호위원회 누리집(pipc.go.kr)”, “개인정보 포털(privacy.go.kr)”에서 확인할 수 있습니다.

일반수신자 등재 안내서